

Control ID	ISO 27001:2022 Control	Annex A Reference	POPIA Requirement	Applicability	Current Status	Maturity Level (1-5)	Control Owner	Evidence Required	Gap Identified	Remediation Action	Priority	Target Date
CTL-001	Information Security Policy	A.5.1	POPIA Section 19	Applicable	Not Implemented	1	CEO/Director	Approved policy document	YES - No policy exists	Draft and approve master Information Security Policy	CRITICAL	Month 1
CTL-002	Information Security Roles	A.5.2	POPIA Section 55	Applicable	Partially Implemented	2	CEO/Director	Job descriptions with security duties	YES - No Information Officer appointed	Appoint and register Information Officer with Information Regulator	CRITICAL	Month 1
CTL-003	Segregation of Duties	A.5.3	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	Access control matrix showing role separation	PARTIAL - Some roles share admin access	Review and separate admin and user access roles	HIGH	Month 2
CTL-004	Asset Inventory	A.5.9	POPIA Section 14	Applicable	Partially Implemented	2	IT Manager	Complete asset register	PARTIAL - Asset register incomplete	Complete and maintain full asset register (done in this project)	HIGH	Month 1
CTL-005	Classification of Information	A.5.12	POPIA Section 19	Applicable	Not Implemented	1	IT Manager	Classification policy and labeled assets	YES - No classification scheme exists	Implement 4-level classification: Public, Internal, Confidential, Strictly Confidential	HIGH	Month 2
CTL-006	User Access Management	A.8.2	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	Access request forms, approval records	PARTIAL - No formal process documented	Document formal access request and approval process	HIGH	Month 2
CTL-007	User Authentication	A.8.5	POPIA Section 19	Applicable	Not Implemented	1	IT Manager	MFA enabled, screenshots of config	YES - Single factor auth only	Enable MFA on Microsoft 365 and Patient Health Record System	CRITICAL	Month 1
CTL-008	Access Rights Review	A.8.2	POPIA Section 19	Applicable	Not Implemented	1	IT Manager	Quarterly access review records	YES - No regular review done	Implement quarterly access rights review process	HIGH	Month 3
CTL-009	Malware Protection	A.8.7	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	AV software installed, update logs	PARTIAL - Not on all devices	Deploy antivirus to all 35 laptops and 10 mobile devices	HIGH	Month 1
CTL-010	Data Backup	A.8.13	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	Backup logs, restoration test results	PARTIAL - Backups not tested	Implement and TEST backup restoration monthly	HIGH	Month 2
CTL-011	Event Logging	A.8.15	POPIA Section 19	Applicable	Not Implemented	1	IT Manager	Log management system screenshots	YES - No centralised logging	Enable audit logging on all critical systems including PHRS	HIGH	Month 3
CTL-012	Network Security Controls	A.8.20	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	Firewall config, network diagram	PARTIAL - Firewall rules undocumented	Document and review all firewall rules and network segments	HIGH	Month 2
CTL-013	Encryption of Data	A.8.24	POPIA Section 19	Applicable	Partially Implemented	2	IT Manager	Encryption certificates	PARTIAL - Laptops not all encrypted	Enable BitLocker encryption on all 35 staff laptops	Critical	Month 1
CTL-014	Security Awareness Training	A.6.3	POPIA Section 19(2)	Applicable	Not Implemented	1	HR Manager	Training records, attendance registers	YES - No formal training exists	Develop and deliver annual POPIA and security awareness training	HIGH	Month 3
CTL-015	Information Security Incident Management	A.5.26	POPIA Section 22	Applicable	Not Implemented	1	IT Manager	IR plan document, incident log	YES - No IR procedure exists	Write and test Incident Response Plan including POPIA 72-hour breach notification procedure	CRITICAL	Month 2
CTL-016	Supplier Security Requirements	A.5.19	POPIA Section 21	Applicable	Not Implemented	1	GRC Analyst	Vendor contracts, assessment reports	YES - No vendor assessments done	Implement vendor assessment process and review all lab and pharmacy partner agreements	HIGH	Month 4
CTL-017	Physical Security Perimeter	A.7.1	POPIA Section 19	Applicable	Partially Implemented	2	Facilities Manager	Access logs, CCTV records	PARTIAL - No server room access log	Implement formal physical access log for server room	MEDIUM	Month 3
CTL-018	Clear Desk and Screen Policy	A.7.7	POPIA Section 19	Applicable	Not Implemented	1	All Staff	Policy document, compliance checks	YES - Patient files left on desks	Implement and enforce clear desk policy for all clinical staff	HIGH	Month 2
CTL-019	Secure Disposal of Equipment	A.7.14	POPIA Section 14	Applicable	Not Implemented	1	IT Manager	Disposal certificates, data wiping logs	YES - No secure disposal process	Implement secure data wiping procedure before device disposal	HIGH	Month 3
CTL-020	Privacy Impact Assessment	A.5.34	POPIA Section 19	Applicable	Not Implemented	1	Information Officer	Completed PIA documents	YES - No PIA process exists	Conduct Privacy Impact Assessment for Patient Health Record System and Telehealth Platform	HIGH	Month 4